

מפגש 6 – ניהול סיכונים - מתודולוגיות לניהול סיכוני סייבר

סקירה מקיפה של ניהול סיכוני סייבר בארגונים, הדגשת חשיבות מתודולוגיה מובנית להגנה אפקטיבית מפני איומים דיגיטליים.

ד"ר מיכאל טיבין



הערכת הסיכונים

4 קטסטרופה	3 קריטי	2 פחות חשוב	1 זניח	הסתברות/חומרה
				1 - שכיח
				2 - סביר שיקרה
				3 - קורה לפעמים
				4 - לעיתים רחוקות
				5 - נדיר ביותר



התמודדות עם הסיכונים

4

3

2

1

הימנעות

הימנעות מביצוע פעילות שעלולה ליצור סיכון.

קבלה

קבלת הסיכון, תוך הכרה בהשפעות הפוטנציאליות.

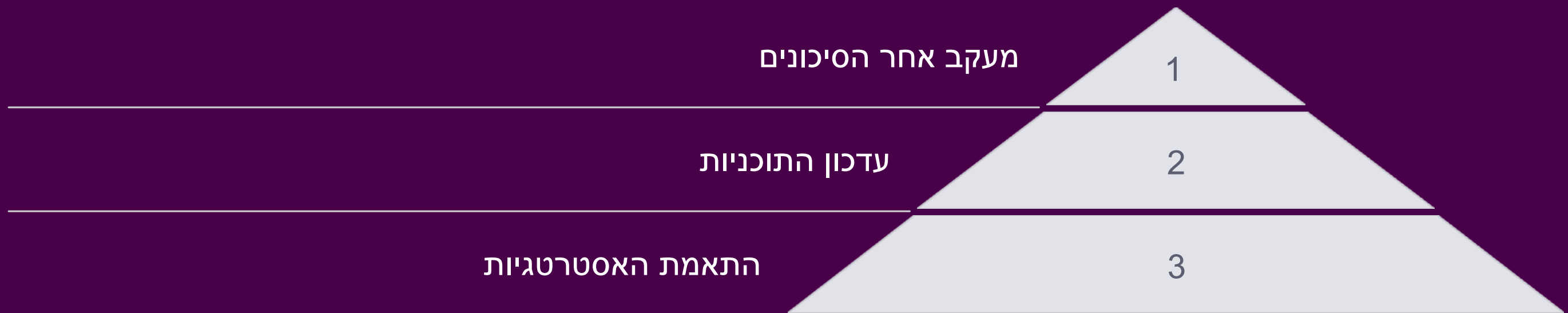
העברה

העברת הסיכון לצד שלישי, כגון ביטוח.

הפחתה

נקיטת צעדים לצמצום הסבירות או ההשפעה של הסיכון.

ניטור והבקרה של הסיכונים



תקשורת ודיווח על סיכונים

1

דו"חות

דיווח קבוע על הסיכונים המרכזיים.

2

פגישות

דיון בסוגיות ובהתפתחויות.

3

מערכת

שיתוף מידע וניהול תיעוד.



אחריות וחשיפה לסיכונים

הנהלה

1

אחריות כוללת לניהול הסיכונים

מנהלי תחומים

2

אחריות לזיהוי וניהול סיכונים בתחומם

עובדים

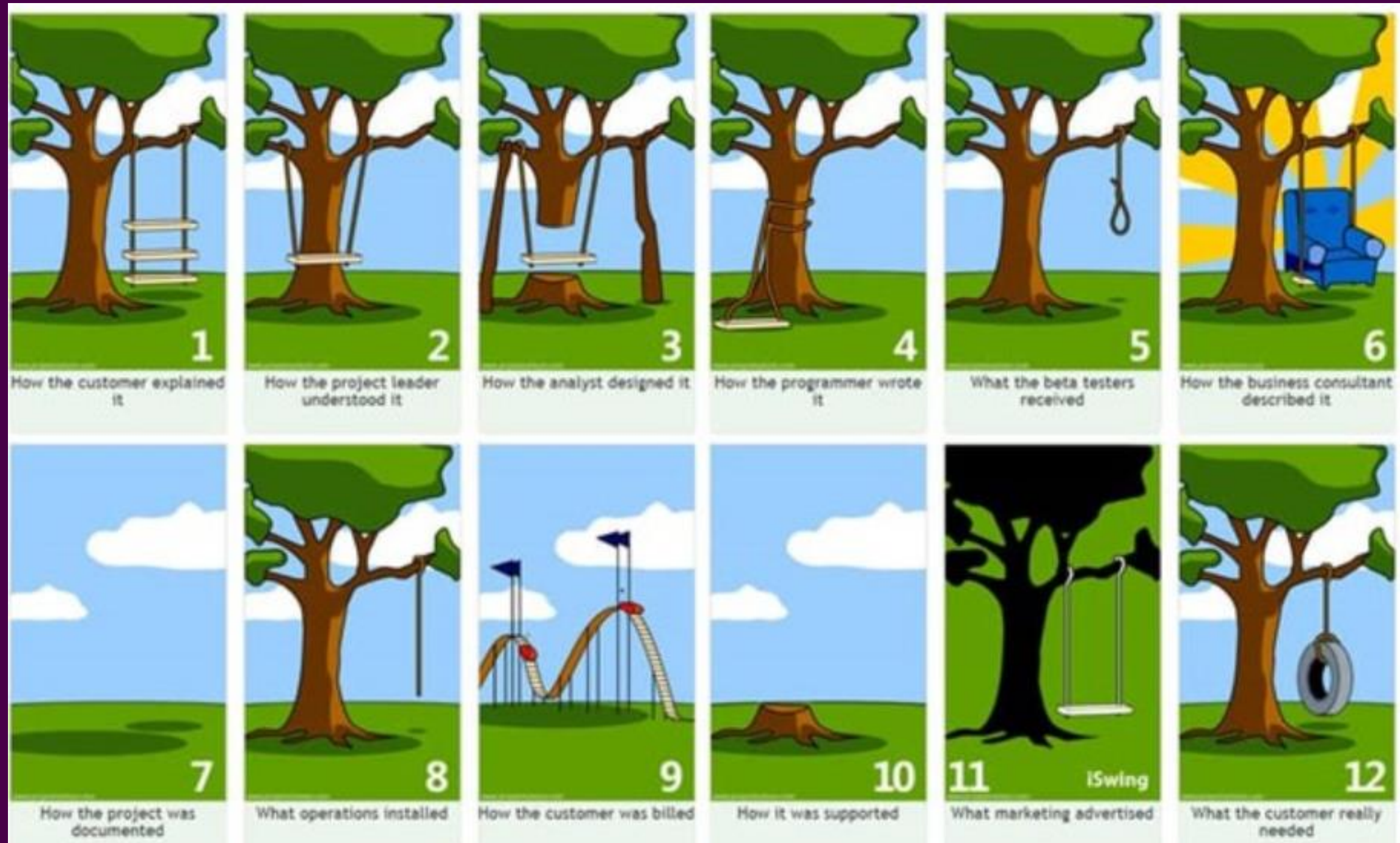
3

חובה לדווח על סיכונים

ניהול סיכונים



ניהול סיכונים – רצוי מול מצוי



שלבי יישום תוכנית ניהול סיכוני סייבר

1 מיפוי מערכות מידע, נתונים, נכסים דיגיטליים ורשתות תקשורת

2 קביעת רמת קריטיות / חשיבות של כול נכס לפי ההשפעה העסקית שלו

3 ניתוח שרשרת האספקה והערכת ספקים חיצוניים (ולפעמים את הסיכונים שלהם)

Business
Impact
Analysis (BIA)



Data
Classification



Asset
Inventory



אירוע סייבר – בית חולים הלל יפה

באוקטובר 2021, בית החולים הלל יפה בחדרה ספג מתקפת כופרה חמורה ששיבשה את פעילותו בצורה משמעותית. מדובר באחת מתקיפות הסייבר המשמעותיות על תשתיות בריאות בישראל.

מה קרה באמת ?

- האקרים הצליחו לחדור למערכות המידע של בית החולים ולהצפין נתונים רגישים
- מערכות תפעוליות קריטיות, כולל מערכת ניהול רשומות רפואיות מערכת (ERM), מערכות מעבדה ודימות הושבתו.
- צוותי בית החולים נאלצו לעבור לעבודה ידנית – ניהול רשומות רפואיות בכתב יד
- חולים במצבים דחופים הופנו לבתי חולים אחרים, וחלק מהניתוחים בוטלו



אירוע סייבר – בית חולים הילל יפה

סוג מתקפה

- מתקפת Ransomware – כופר
- שיטת התקיפה
- חדירה דרך מתקפת פשינג (ייתכן דרך מייל או קובץ נגוע)
- הצפנה של קבצים ומוסדי נתונים קריטיים
- דרישת כופר תמורת שחרור המידע

• החשד:

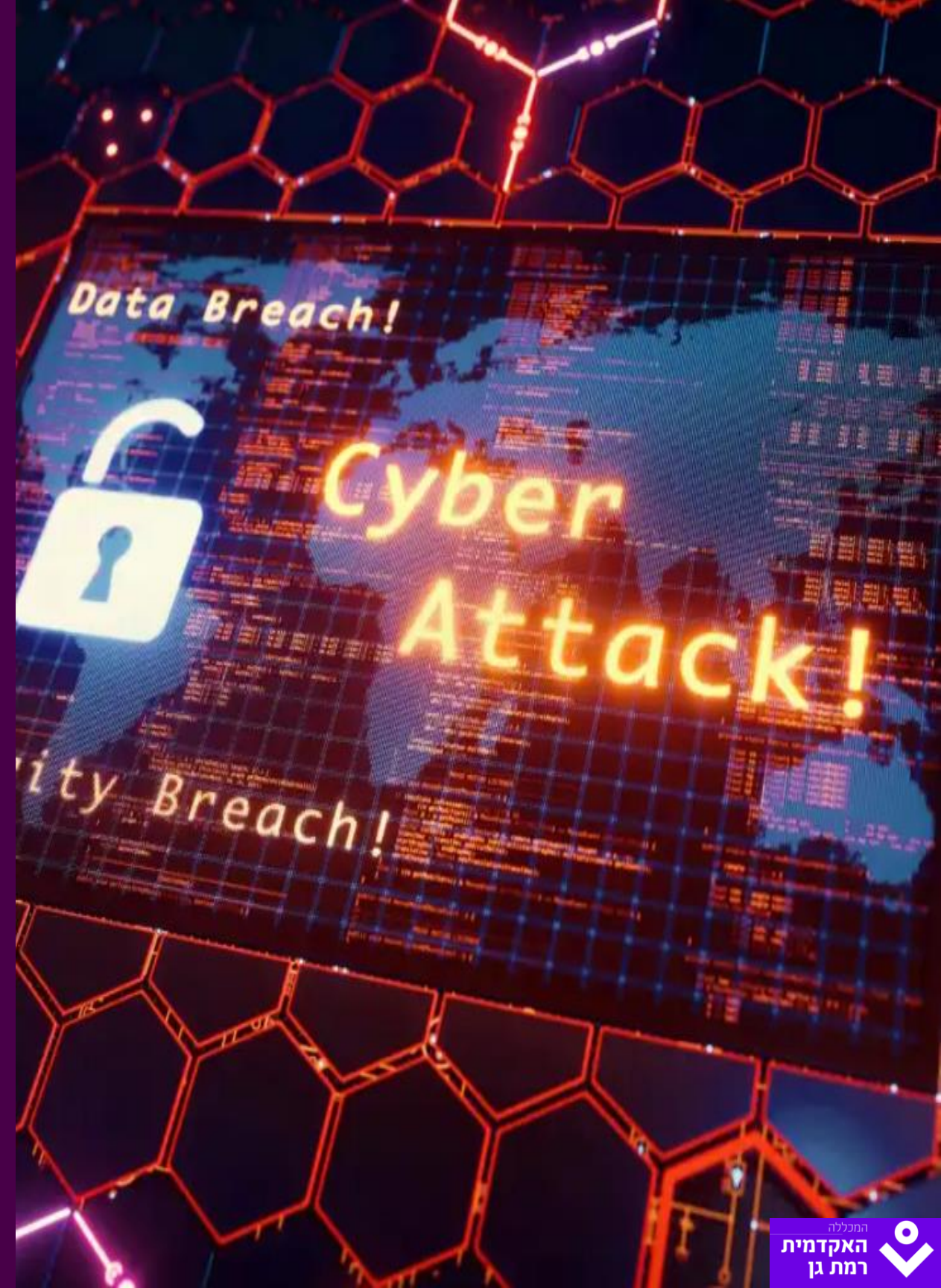
- מדובר בתקיפה מתוכננת של קבוצת האקרים בינלאומית
- ככל הנראה, מדובר בגורמים שלא פעלו ישירות נגד ישראל, אלא התקפה ממוקדת כללית



אירוע סייבר – בית חולים הילל יפה

השפעות והתגובה של בית החולים:

- מערכות מחשוב קריטיות הושבתו למשך ימים, והתאוששות מלאה לקחה שבועות
- מטופלים נאלצו להיות מעוברים לבתי חולים אחרים
- צוותי אבטחת סייבר ממשד הבריאות משרד הארצי לניהול אירועי סייבר נכנסו לפעולה
- חקירה נפתחה כדי להבין כיצד האקרים חדרו למערכות ומה גנבו



אירוע סייבר – בית חולים הילל יפה

תהליך התאוששות

שלבים עיקריים בניהול המשבר:

- בידוד השרתים שנפגעו ומניעת התפשטות הנזק
- הפעלת תהליכי עבודה ידניים כדי להמשיך לטפל בחולים
- ניתוח Forensic לזיהוי דרך החדירה והיקף הנזק
- הקמה מחדש של מערכת המידע על בסיס גיבויים
- חיזור ההגנות והגברת המודעות לעובדים



אירוע סייבר – בית חולים הילל יפה

מסקנות והפקת לקחים

בתי חולים הם מטרה רכה ופגיעה למתקפות סייבר בשל התלות במערכות המידע

- גיבויים מאובטחים ושחזור מהיר – קריטיים למניעת שיתוק מוחלט
- בידוד של מערכת – מרוץ נגד הזמן
- הדרכות צוותים רפואיים לזיהוי מתקפות פשינג והימנעות מלחיצה על קישורים חשופים
- חיזוק מנגנוני ZERO TRUST SECURITY , וניהול הרשאות הדוק יותר

בשנת 2023 שיבא והדסה היו תחת מתקפות סייבר, אז ללא נזקים, ההתקפות סוכלו

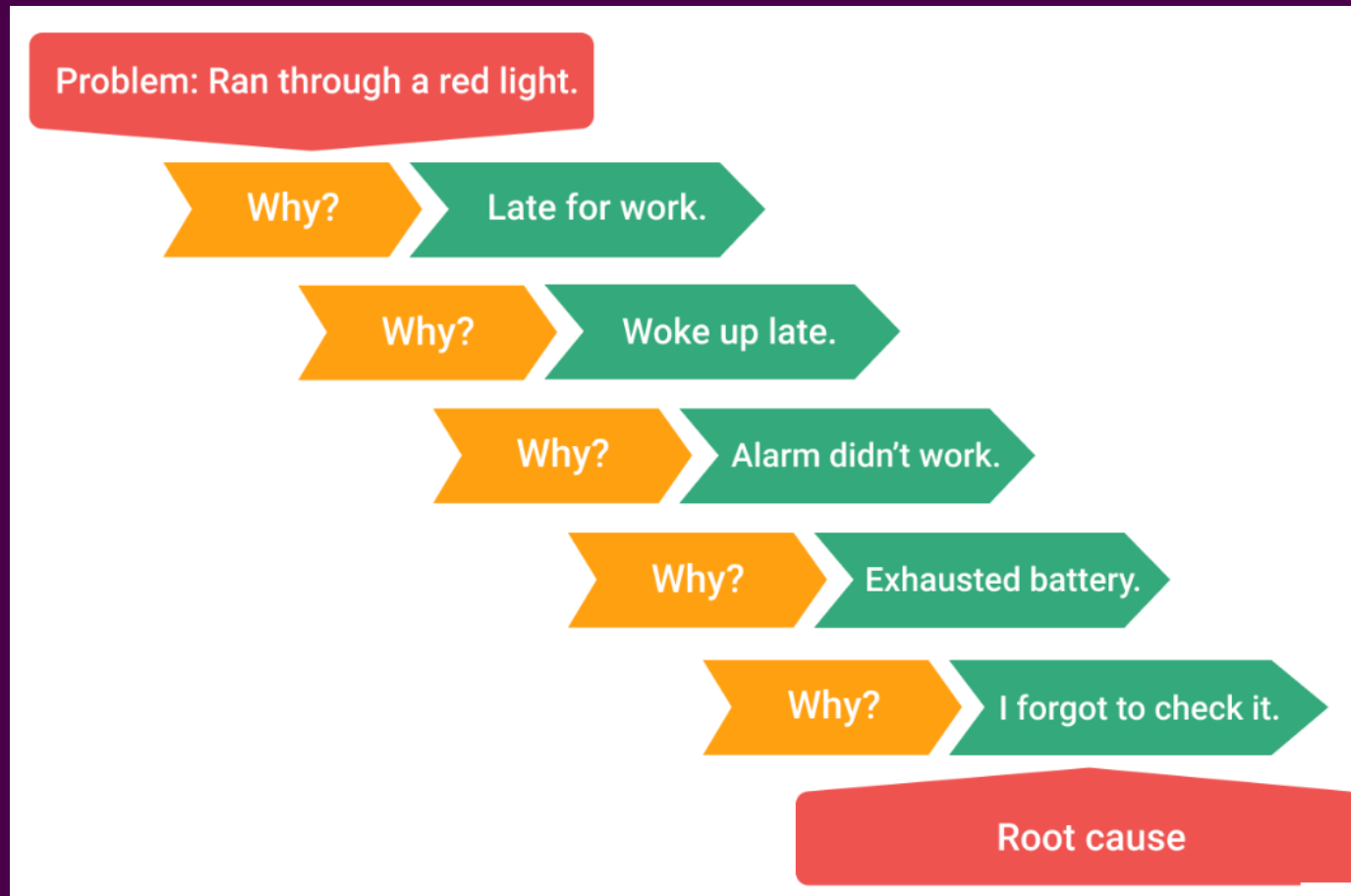


Ransomware

ניתוח שורש הבעיה



5 Y's



- חמשת למה, לרדת לשורש הבעיה
- עוזר למצוא ולפתור את שורש הבעיה

ששת כובעי חשיבה של בונו

Created in 1983 by Edward de Bono •

• שיטת חשיבה שמטרתה שיפור תהליך קבלת ההחלטות בקבוצות. במסגרת השיטה, המשתתפים בדיון מבצעים משחק תפקידים בהתאם לכובע הדמיוני שהם חובשים

- כובע לבן - עובדות, נתונים ומידע. חשיבה נייטרלית, משמעת והכוונה. ...
- כובע אדום - רגשות, תחושות ואינטואיציה. ...
- כובע שחור - שיפוט שלילי, מדוע לא יצליח (תפקיד פרקליט השטן). ...
- כובע צהוב - גישה חיובית ואופטימית, הזדמנויות. ...
- כובע ירוק - יצירתיות וצמיחת חשיבה יצירתית, חיפוש חלופות. ...
- כובע כחול - רוגע ושליטה.



Facts



Creativity



Benefits



Cautions



Feelings



Process

MoSCoW



MUST HAVE

All the requirements that are necessary for the successful completion of the project.



SHOULD HAVE

Requirements that are important for project completion but not necessary.



COULD HAVE

Requirements that are nice to have, but have a much smaller impact when left out of the project.



WILL NOT HAVE

All the requirements that have been recognized as not a priority for the project's timeframe.

RISK MANAGEMENT METHODOLOGY



In Cyber Security

NIST Cybersecurity Framework (CSF)

Detect – ניטור מתמשך
לזיהוי איומים

Protect – יישום בקרות
אבטחה להקטנת חשיפה

Identify - זיהוי נכסים קריטיים
וסיכונים פוטנציאליים

Recover – תכנון
התאוששות ושיפור
לאחר מתקפה

Respond - פיתוח
תוכנית תגובה לאירועים

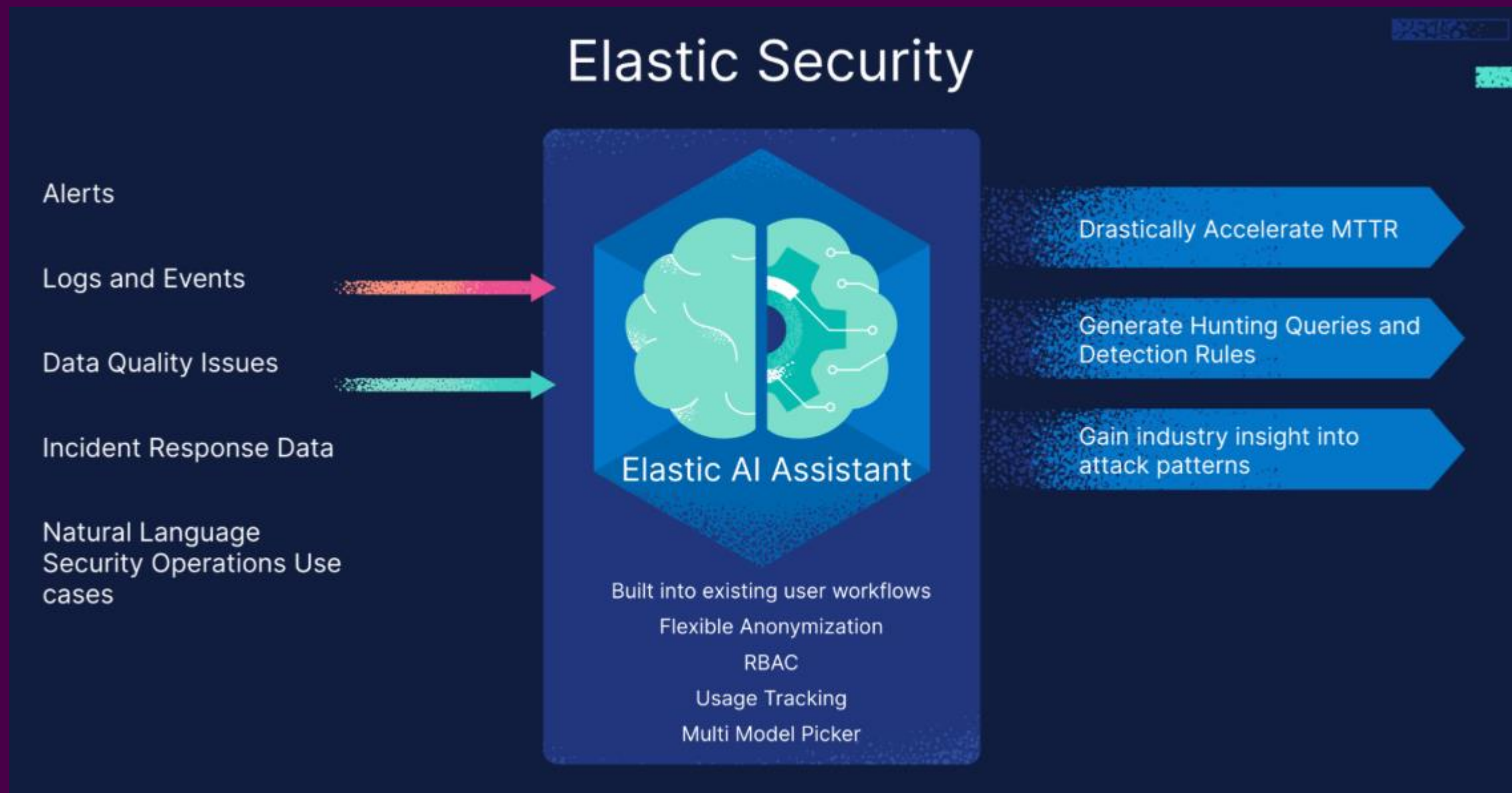


ארגונים גדולים
וממשלתיים

רגולציה מחמירה

ניהול אבטחה
כוללני

Third Party Tools – Supply Chain ?



ניהול סיכוני אבטחת מידע – ISO/IEC 27005

הגדרת היקף והקשרים עסקיים

זיהוי סיכונים: נכסים, איומים, פגיעויות

הערכת סיכונים: ניתוח השפעה והסתברות

טיפול בסיכונים: הקטנה, העברה, קבלה או מניעה

ניטור ושיפור מתמיד

ארגונים המחויבים
לתקני ISO
27001

מגזרים פיננסיים

חברות גלובאליות

דוגמאות

SSO Management

Admin

Search for users, groups or settings

Generative AI

Security

Overview

Security advisor

Alert center

Authentication

2-step verification

Account recovery

Advanced Protection Program

Login challenges

Passwordless

Password management

SSO with SAML applications

SSO with third party idP

Multi-party approval

Multi-party approval settings

Access and data control

Data

Reporting

Billing

Account

Rules

Storage

Send feedback

Security > SSO with third-party IDPs

Single sign-on (SSO) with third-party identity providers (IDPs)

Set up SSO so users can sign in with a third-party IDP to access Google Workspace services. [Learn more](#)

Third-party SSO profile for your organization

Add a third-party SSO profile for your organization

This SSO requirement will apply to all users in your organization. [Learn more](#)

ADD SSO PROFILE

Third-party SSO profiles

Below are SSO profiles you can assign to organizational units or groups. Add new SSO profiles or use the default OIDC profile available below. [ADD SAML PROFILE](#)

Name	Type	Status
Akamai SSO Test	SAML	Complete
Microsoft	OIDC	BETA System profile

Manage SSO profile assignments

View and manage assignments for organizational units or groups. [Learn more](#)

MANAGE

Name	Type	SSO profile
guardicore.com > Bots	Organizational unit	None (users will sign in with Google)
guardicore.com > Test SSO	Organizational unit	Akamai SSO Test - SAML
guardicore.com	Organizational unit	Akamai SSO Test - SAML

MFA

Admin

Search for users, groups or settings

Home

Dashboard

Directory

Devices

Apps

Security

Overview

Alert center

Authentication

2-step verification

Account recovery

Advanced Protection Program

Login challenges

Passwordless

Password management

SSO with SAML applications

SSO with third party idP

Access and data control

Reporting

Billing

Account

Rules

Storage

Send feedback

Security > 2-Step Verification

Security Settings

Organizational Units

Search for organizational units

guardicore.com

Bots

Drive Off

Employees

External Contractors

Fed

Investors

no_2FA

Trusted External Contractors

Groups

Customize settings for a group within an organizational unit. One group per organizational unit. [Learn more](#)

2FA Off

2facoff@guardicore.com

Authentication

Locally applied

Add an extra layer of security to user accounts by asking users to verify their identity when they enter a username and password. [Learn more](#)

Allow users to turn on 2-Step Verification

Enforcement

Off

On

On from

Date

New user enrollment period

Allows new users some time to enroll before enforcement is applied

1 week

Frequency

Users can avoid repeated 2-Step Verification at login on their trusted devices. [Learn more](#)

Allow user to trust the device

Methods

Select the method to enforce. [Learn more](#)

Any

Any except verification codes via text, phone call

Only security key

2-Step Verification policy suspension grace period

Let users temporarily sign in with verification codes in addition to their security keys. The user's exception period starts when you generate verification codes.

1 day

Security codes

Security codes are single-use codes that can be used where security keys are not supported. Users can generate these codes from [https://go.2s.com](#). [Learn more](#)

Don't allow users to generate security codes

Allow security codes without remote access

Users can generate security codes for use on the same device or local network (NAT or LAN).

Allow security codes with remote access

Users can generate codes for use across devices or networks, such as when accessing a remote server.

CANCEL SAVE

המכללה
האקדמי
רמת גן

איך באמת ניראת בדיקה חיצונית ?

AGS SOC 2 Controls - 2024

File Edit View Insert Format Data Tools Extensions Help

100% 123 Arial 11 B I A

Control Owner

	A	B	C	D	E	F	G	H
	Control Number	2024 Control Description	Expected evidence	Control Owner	Evidence repository	Audit Status	Auditor's Additional Comments	Akamai's Additional Comments
1	AGS 1.1.2	New employees are required to sign a standard employment agreement outlining the confidentiality and the intellectual property clauses.	• NDA template (not signed). • Testing: - AGS will provide the signed NDA for the selected employees."	HR	AGS 1.1.2	Accepted & closed	October 9, Yaron: Please provide the NDA for Yuji Ohara, Employees number: 31325	[Pawel Sep 26] Created new control and will attach the evidence based on API Security control testing. [Pawel Oct 1] Evidence uploaded [Pawel Oct 14] Yuji is based in Japan where we don't do NDAs - they are handed a document called Work Rule, they don't sign it though. I have attached the document in our drive.
2	AGS 1.5.1	An organization chart is documented that clearly defines management authorities and reporting hierarchy.	• Organizational chart (include only job titles, not individual names)	SOC 2 team	AGS 1.5.1	Accepted & closed	Pls update the date	[Pawel Aug 20] Evidence uploaded
4	AGS 2.1.1	Akamai provides a support portal to assist customers and internal users in utilizing the product and accessing system documentation to mitigate the risk of operational inefficiencies, misconfiguration, or inadequate understanding of the system by customers.	• Screenshot of the support portal • User guide		AGS 2.1.1	Accepted & closed		
5	AGS 6.1.1	Access to system resources is protected through a combination of firewalls, VPNs, native operating system security, database management system security, application controls and intrusion detection monitoring software.	• The architecture diagram	SOC 2 team	AGS 6.1.1	Accepted & closed		
9	AGS 6.2.1	Terminated employees who had access to the production environment have their permissions removed in a timely manner.	• A sample of a termination checklist • Testing: 1. Guardicore will provide a list of employees terminated during the audit period 2. EY will choose a sample 3. Guardicore will provide completed offboarding checklists for the terminated employee	SOC 2 team	AGS 6.2.1	Accepted & closed	September 17, Yaron: Any update on the evidence for the selected sample? (the mail was sent on September 4) Nathan OJ Whittaker, Mitchell Bolado, Nayana Raviraj Hegde, Joel Munoz, Omar Guillermo Hernandez, Altantuya Amgalan, Priyanka Chanda, Tanzeem Pasha, Shlomi Salman, Roland Harallambi, Ajitesh Nair, Jeffry David Solano, Artur Foden, Kevin Kalin, Kamil Demeter, Jamie Ingle, Priyaranjan Dalai, Harvi Patel, Yeiner Solano, Brian Arias, Kandlapalle Nikhil, Aishwarya Vanikar, James King, Ignatius Mudoh, Saba Abdul Razzaque Karigar. September 25, Yaron: Please provide the termination documentation for the following: David (Dave) Walker, David C Kaplowitz, Nathan OJ	[Pawel Sep 18] With IT Swarup at the moment [Pawel Sep 24] Evidence uploaded - three samples 24868 Altantuya Amgalan aamgalan, 29903 Jamie Ingle jingle and 25581 Tanzeem Pasha tpasha were contingent workers and were converted to regular FTE so their access has not been cut off. So technically they have not been terminated and they still work in Akamai. Would you like to reselect for those three? [Pawel Sep 25] Send to IT. Waiting for response [Pawel Sep 25] resamples evidence uploaded
11								

המכללה

האקדמית

רמת גן

FAIR Model – Factor Analysis of Information Risk

חישוב הסתברות של מתקפה
מוצלחת

זיהוי נכסים קריטיים ואיומים
רלוואנטיים

בקורות אבטחה (הערכת החזר
על השקעה ROI)

ניתוח הפסדים פוטנציאליים
(כספיים, תפעוליים ומוניטין)

דירקטוריונים
ומנהלים פיננסיים

ארגונים הדורשים
הערכת סיכונים
כלכלית מדויקת



OCTAVE – Operationally Critical Threat, Asset, and Vulnerability Evaluation

OCTAVE Allegro – למיקוד מהיר
בנכסים קריטיים



OCTAVE – S – למוסדות קטנים
ובינוניים



OCTAVE Method – מתודולוגיה
רחבה הכוללת הערכת תרחישי
סיכון



SMB's – SMALL
MEDIUM
BUSINESS

ארגונים עם
מודעות עצמית
גבוהה לסיכונים



מסגרת ניהול אבטחת מידע – COBIT 2019



הגדרת בקורות IT וניהול
הרשאות



מיפוי יעדי אבטחה עסקיים



ניטור ויישום מדדי הצלחה –
KPI לניהול סיכונים



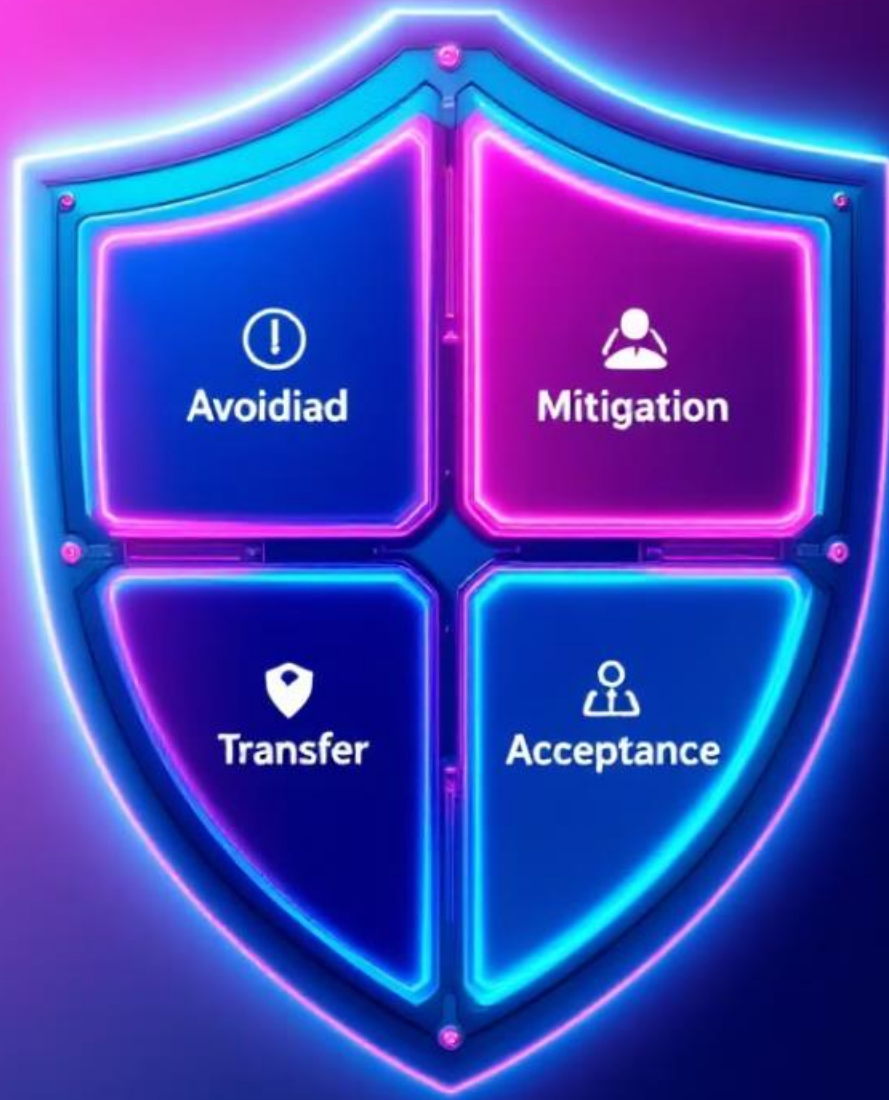
ארגונים פיננסיים

תאגידים גדולים

חברות בעלות
מערכות IT
מורכבות

Risk Management Framework (RMF)

ניהול סיכונים למערכות מידע –



Implement - יישום בקרות
וניטור שוטף



Select - בחירות בקרות אבטחה
מתאימות



Authorize – אישור מערכת
לניהול סיכונים



Assess - בדיקת עמידה
בסטנדרטים ורגולציות



Monitor – ניטור ועדכון מתמיד



מערכות עם
רגולציה מחמירה
(GDPR, HIPAA,)
(FedRAMP)

מוסדות פיננסיים

גופים ממשלתיים

השוואת מתודולוגיות לניהול סיכוני סייבר



מתאים ל...	סוג הערכה	מיקוד עיקרי	מתודולוגיה
ארגונים גדולים, רגולציה מחמירה	שילוב איכותי וכמותי	ניהול אבטחה כולל	NIST CSF
ארגוני IT גדולים	שילוב כמותי ואיכותי	ממשל אבטחת מידע	COBIT 2019
SMB, ארגונים גמישים	איכותי	ניהול עצמי של סיכונים	OCTAVE
דירקטורים, מגזר פיננסי	כמותי	ניתוח פיננסי של סיכונים	FAIR Model
חברות המחויבות לתקני ISO	איכותי	מערכת לניהול אבטחת מידע (ISMS)	ISO 27005
ארגונים גדולים, רגולציה מחמירה	שילוב איכותי וכמותי	ניהול אבטחה כולל	NIST CSF

Q & A

